ETH zürich

Organisationseinheit verbal
optional auf 2 Zeilen

Pitfalls in Phishing Prevention

Why well-intended advice may make things worse

Daniele Lain

Postdoctoral researcher, System Security Group @ ETH Zurich

OWASP Switzerland - 25th Anniversary - 14.10.2026

What is phishing?

[PayPal]: Your account access has been limited

Team Support services@paypal-accounts.com
to **me**

PayPal

Dear PayPal customer,

Your PayPal account is limited, You have 24 hours to solve the problem or your account will be permanetly disabled.

We are sorry to inform you that you no longer have access to PayPal's advantages like purchasing, and sending and receiving money.

Why is my PayPal account limited?
We believe that your account is in danger from unauthorized users.

What can I do to resolve the problem?
You have to confirm all of your account details on our secured server by clicking the link below and following the steps.

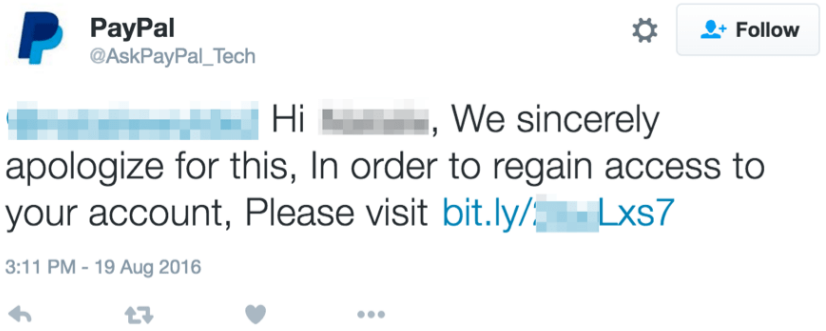
Confirm Your Information

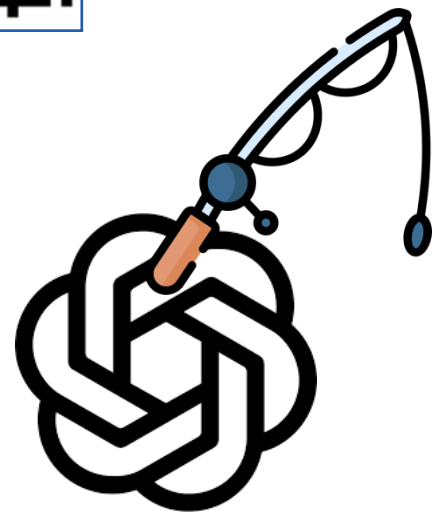
RCS chat with +44 7536 605593

Da die Lieferadresse nicht eindeutig ist, wird Ihre Verpackung nicht zugestellt
Ihr Paket ist zurück in unser Operationscenter
Bitte aktualisieren Sie Ihre Adresse im Link nach dem Lesen der Nachricht, wir werden in 2024/12/18 wieder versenden
https://shorturl.at/QSwW6
Nochmals vielen Dank für Ihre Mitarbeit. Die schweizerische Post.









Common wisdom – Enterprise Edition

1. Phishing training helps its ~~victims~~ pupils
2. If only people knew more about phishing, they wouldn’t fall for it
3. Password managers are a complete solution to the problem

Common wisdom – Enterprise Edition

1. **Phishing training helps its ~~victims~~ pupils**
2. If only people knew more about phishing, they wouldn't fall for it
3. Password managers are a complete solution to the problem

What do phishing and its countermeasures look like in practice?

First **real-world**, **large-scale**, **longitudinal** study on phishing

1. **14,733** company employees measured over **15 months**
2. Diverse population – field, branch, and office workers
3. Randomized, controlled trial with **117,864 phishing emails** in 8 campaigns

Collaboration with phishing awareness & anti-phishing vendors

Daniele Lain, Kari Kostiainen, Srdjan Capkun. *"Phishing in Organizations: Findings from a Large-Scale and Long-Term Study"*. In **IEEE S&P '22**

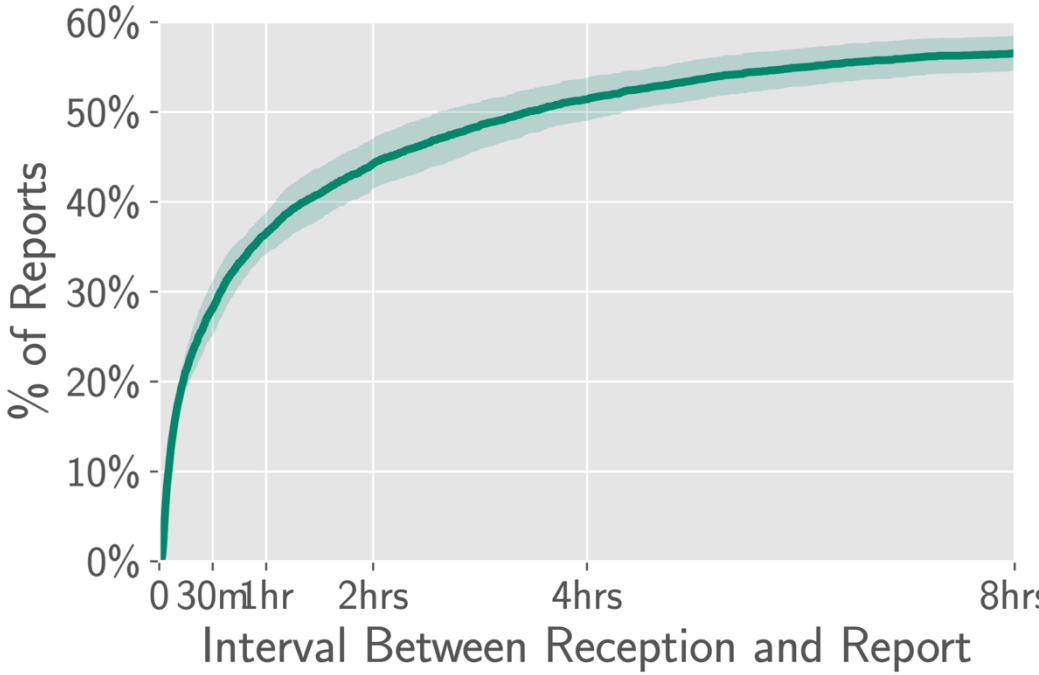
Studying phishing prevention at scale

Ecologically valid evidence on understudied aspects:

1. Phishing susceptibility by demographics
2. Long-term phishing exposure

Confirmed **effectiveness of reporting**

1. “Security champions” often theorized
2. We show they work sustainably
3. **10% of reports within 5 minutes** of reception
4. Blocked **252** campaigns / **~30,000 phishes**



Phishing training

Widespread practice, compliance requirement → multi-million industry

(Unaware) employees receive simulated phishing emails

1. Containing a *lure* (link; attachment)
2. Falling for the simulation (entering credentials; enabling macros)…
3. … Redirects to a *training page*

Training page: **knowledge** on how to spot such attacks in the future



Phishing training *considered harmful?*

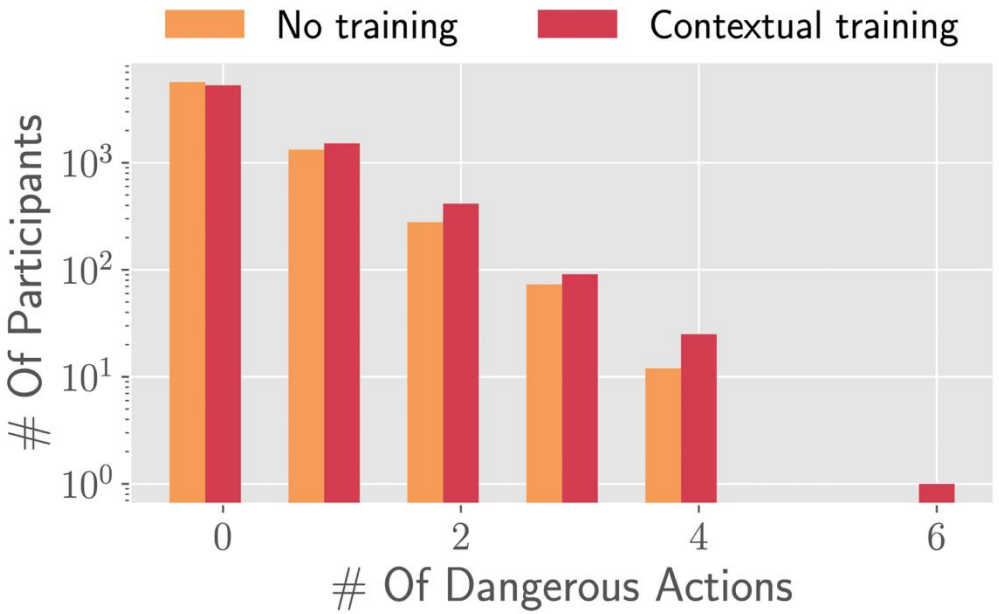
Receiving training → more likely to fall again (and again)

Training correlates with dangerous behavior

1. *Clicking: $F(1, 14{,}592) = 18.37$, $p < 0.001$*
2. *Falling: $F(1, 14{,}279) = 33.80$, $p < 0.001$*

Challenges common intuition

Highly significant: **phishing simulations are ubiquitous**



Common wisdom – Enterprise Edition

1. **Phishing training helps its ~~victims~~ pupils**
   → largely ineffective across groups that need it
2. If only people knew more about phishing, they wouldn't fall for it
3. Password managers are a complete solution to the problem

Common wisdom – Enterprise Edition

1. Phishing training helps its ~~victims~~ pupils
   → largely ineffective across groups that need it
2. **If only people knew more about phishing, they wouldn't fall for it**
3. Password managers are a complete solution to the problem

What causes phishing susceptibility?

We contribute evidence by understanding why training does not work:

1. Effectiveness of its different **components**
2. Potential **improvements**
3. Reception and perceived **needs** of users

Large-scale study on **4,554** company employees

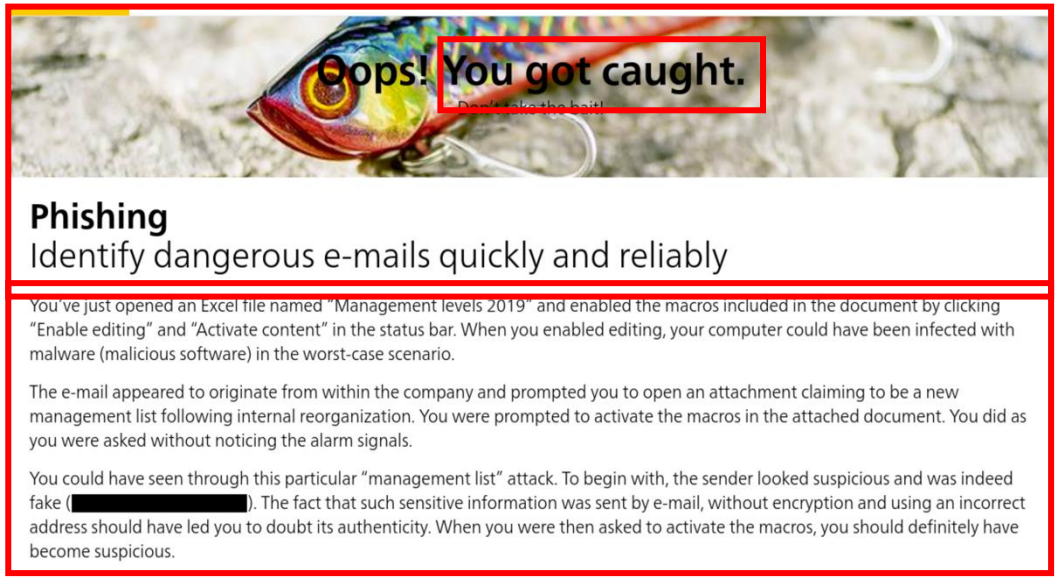
1. Ecological validity: diverse population measured during their workdays
2. 3 simulated phishing emails over 6 weeks

D. Lain, T. Jost, S. Matetic, K. Kostiainen, S. Capkun. *"Content, Nudges and Incentives: A Study on the Effectiveness and Perception of Embedded Phishing Training"*. In **ACM CCS '24 - *Distinguished Paper Award***

Understanding what aspects of training work

Current training practices combine **different aspects**:

1. Knowledge *(considered main goal)*
2. Reminder of threat
3. Consequences
4. Co-location with mistake



Compare **isolated** aspects with training

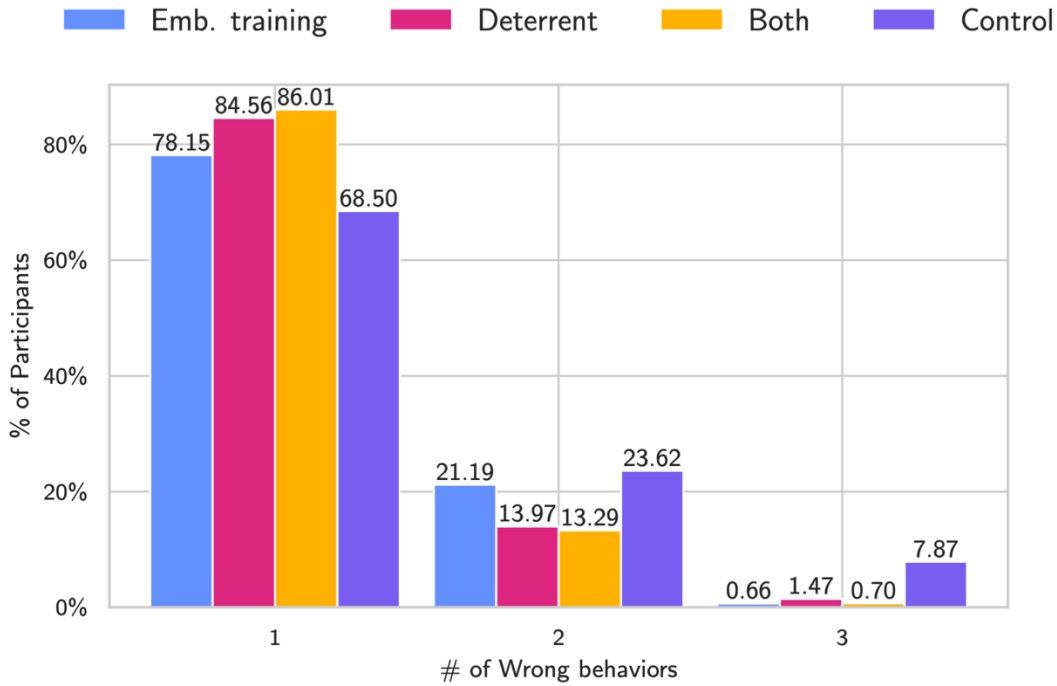
1. **Quantitative**: understand which ones benefit employees
2. **Qualitative**: interview "*worst offenders"* to understand real needs

Training elements: results

Training benefits do not come from educational aspects of the exercise

1. Statistically the same as simple *“deterrents”*
2. … as informing next day
3. **Even enforcing training gave no benefits**

Qualitative: content is known, nudges help



→ Phishing susceptibility is an **attention, rather than knowledge, problem**

Employees know, but struggle to keep awareness

“I just didn’t pay attention and didn’t go any further down. I closed it as soon as I knew it was a phishing email test” – P26

“You look at more carefully but not in the way that you look at these already with the thought in mind that it could be phishing” – P11

→ Employees need **reminders**, not more knowledge

Common wisdom – Enterprise Edition

1. Phishing training helps its ~~victims~~ pupils

   → largely ineffective across groups that need it

2. **If only people knew more about phishing, they wouldn't fall for it**

   → need attention & awareness, how it is delivered not significant

3. Password managers are a complete solution to the problem

Common wisdom – Enterprise Edition

1. Phishing training helps its ~~victims~~ pupils

   → largely ineffective across groups that need it

2. If only people knew more about phishing, they wouldn't fall for it

   → need attention & awareness, how it is delivered not significant

3. **Password managers are a complete solution to the problem**

Do password managers protect against phishing?

~~Do password managers protect against phishing?~~

Can we phish a password manager's *master password*?

Sign In

login.anywebsite.com/?app_id=db44e2bb23e8



Single Sign-On

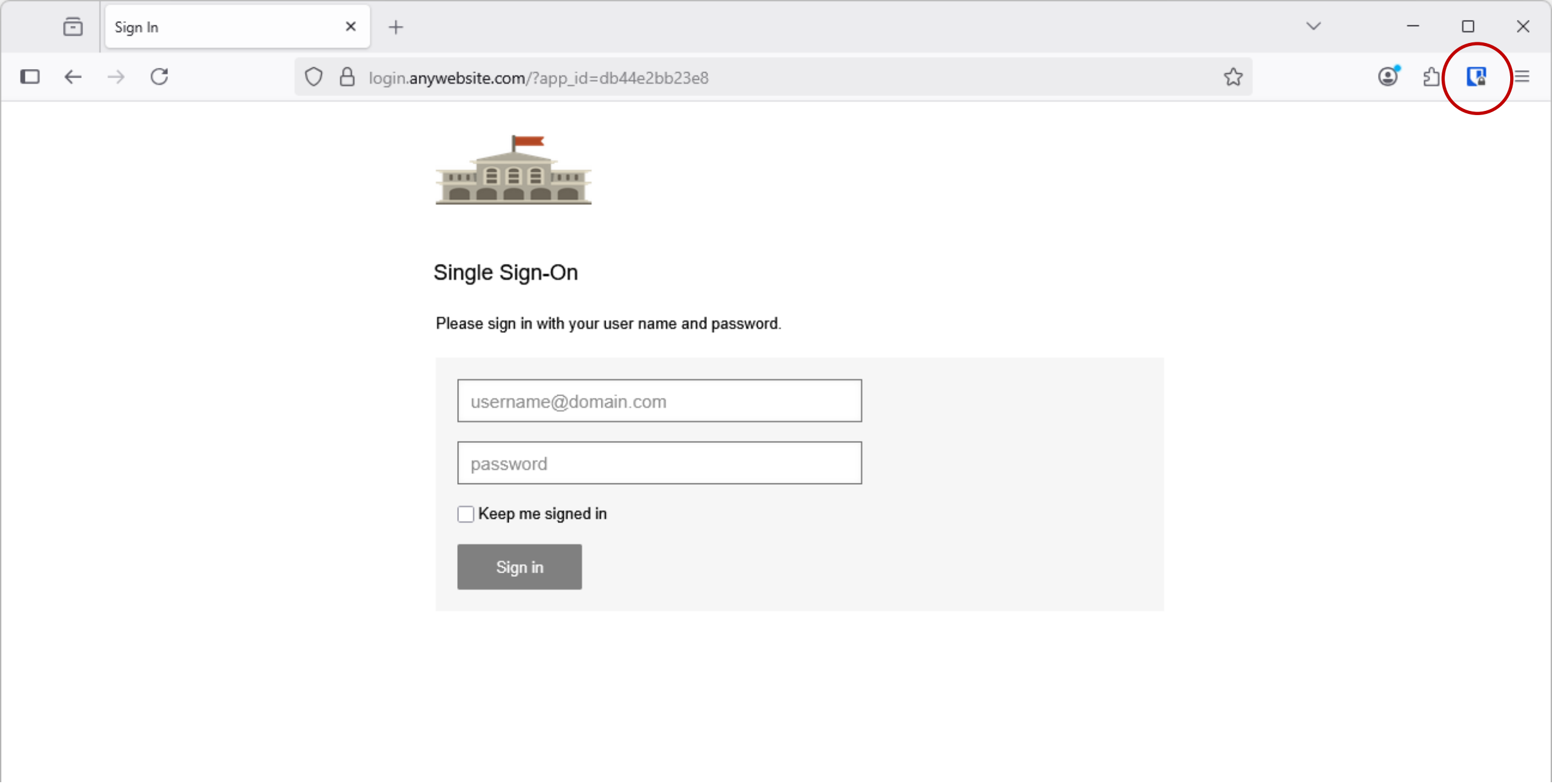
Please sign in with your user name and password.

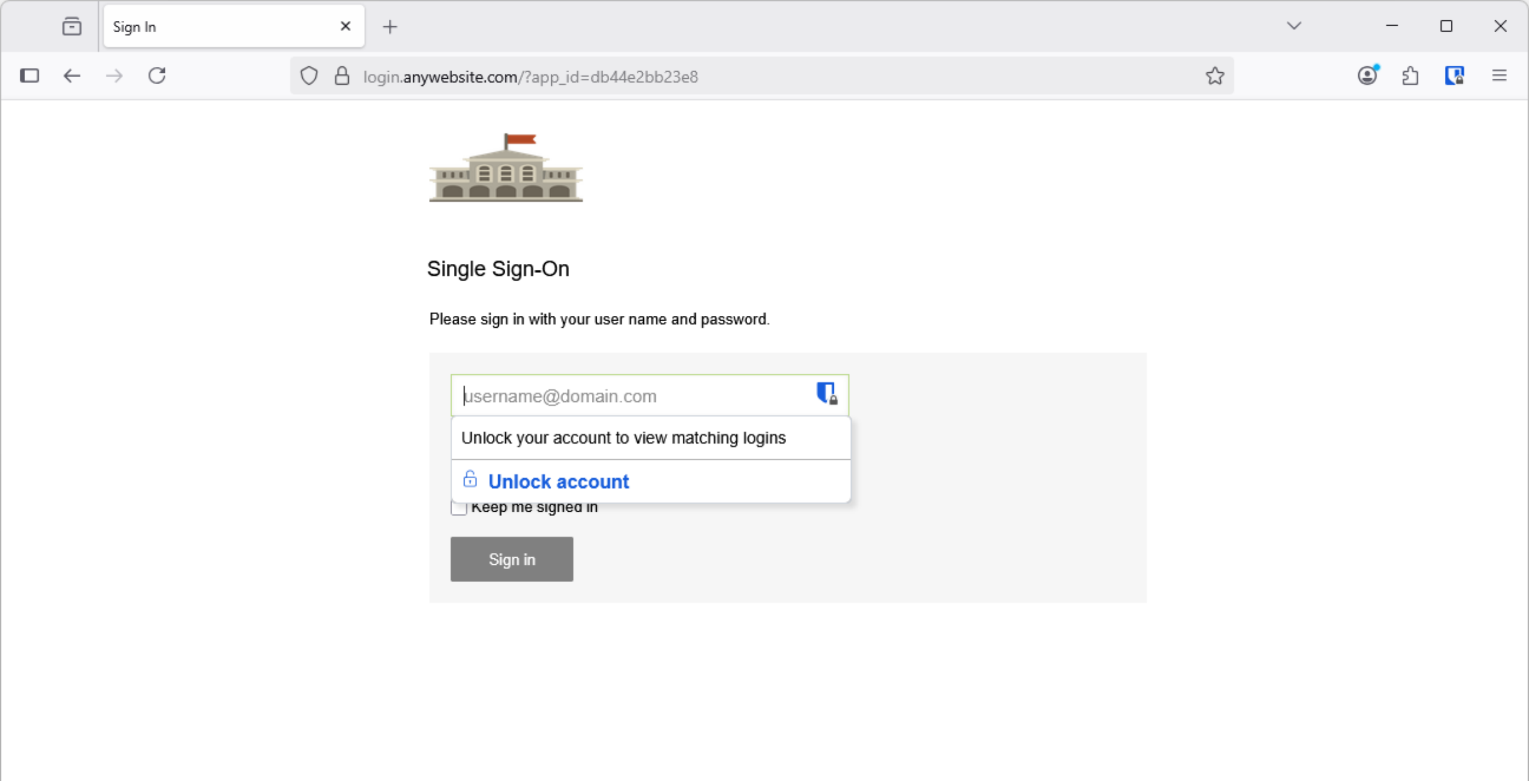
username@domain.com

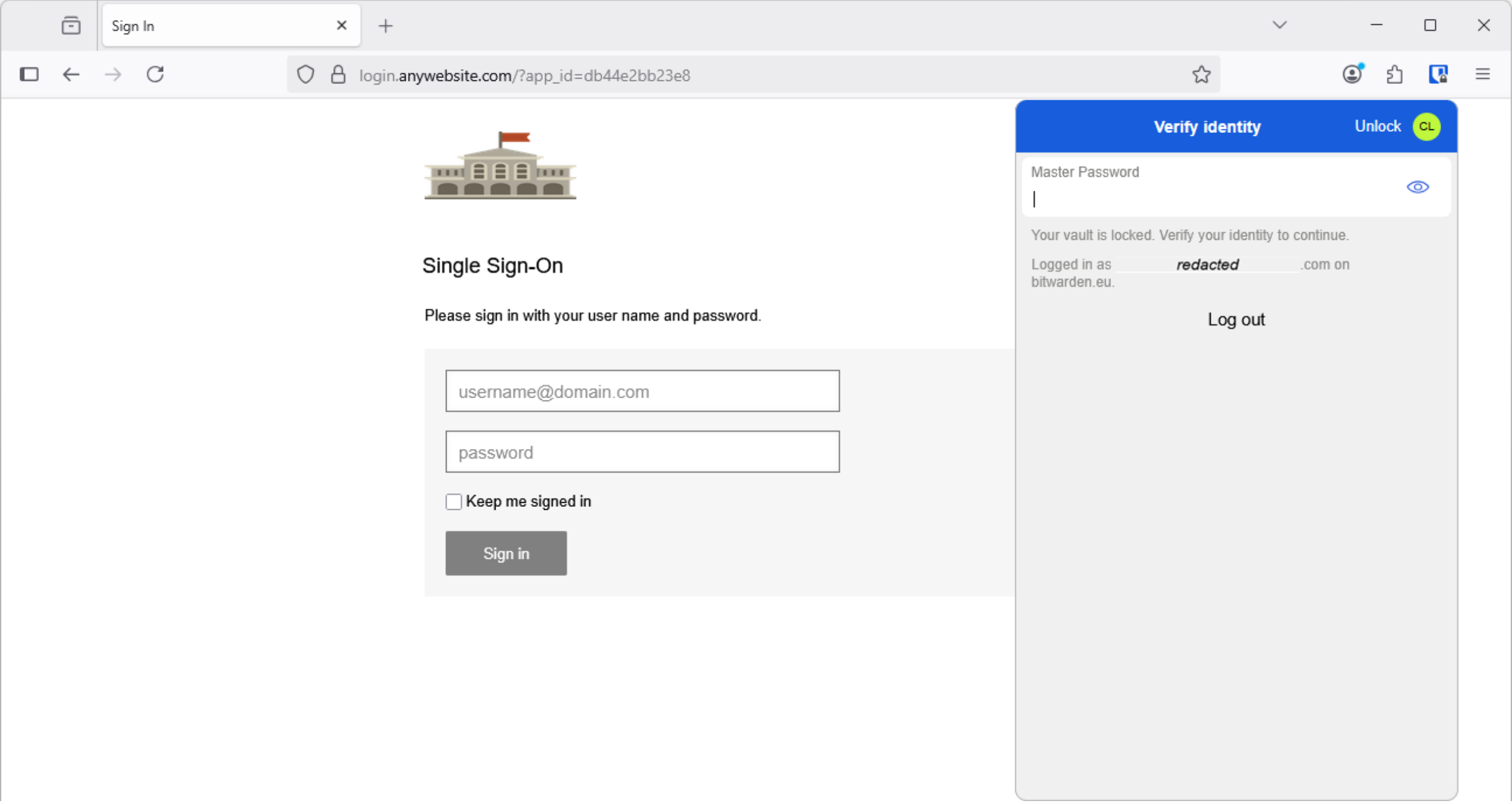
password

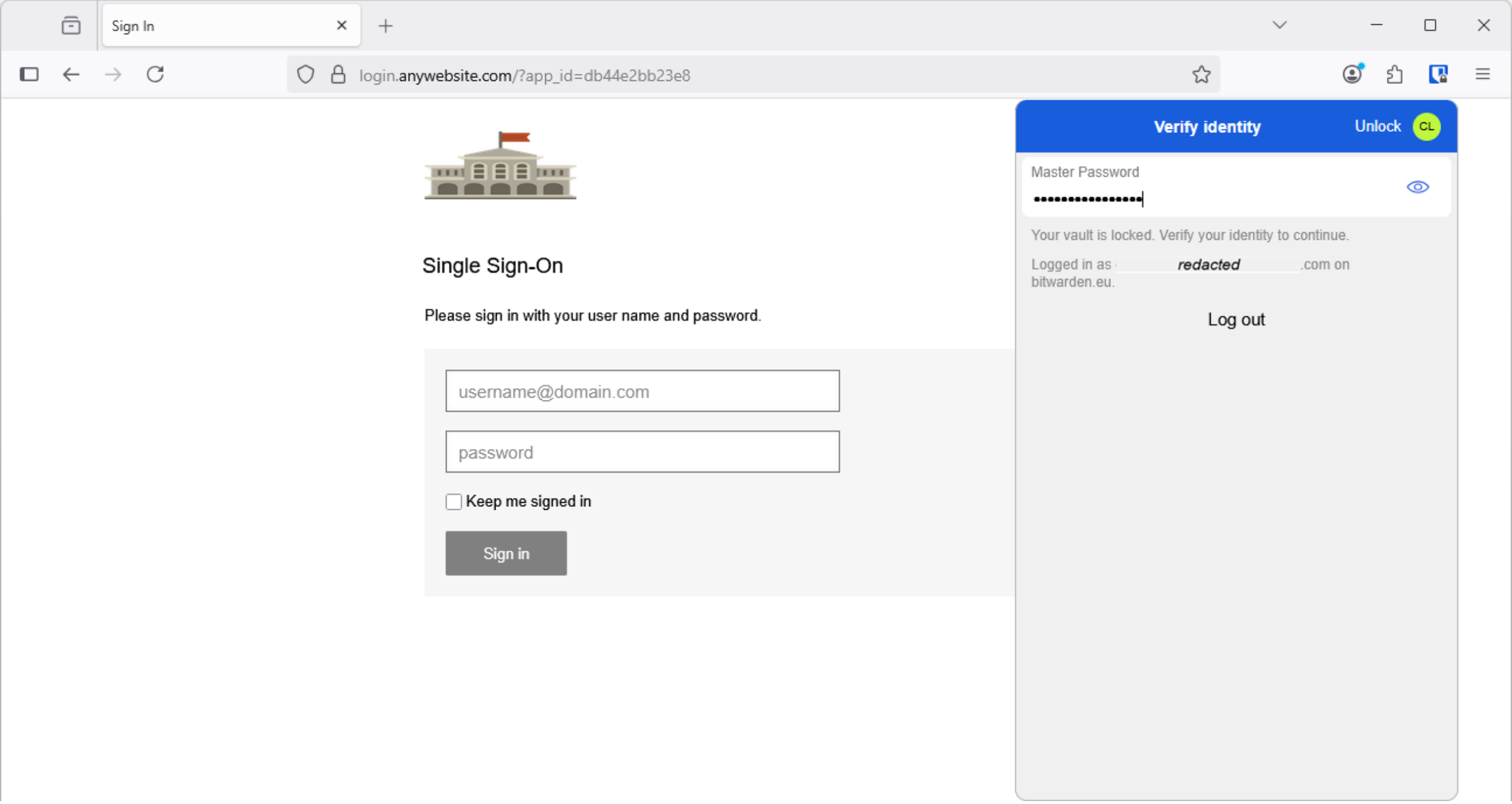
Keep me signed in

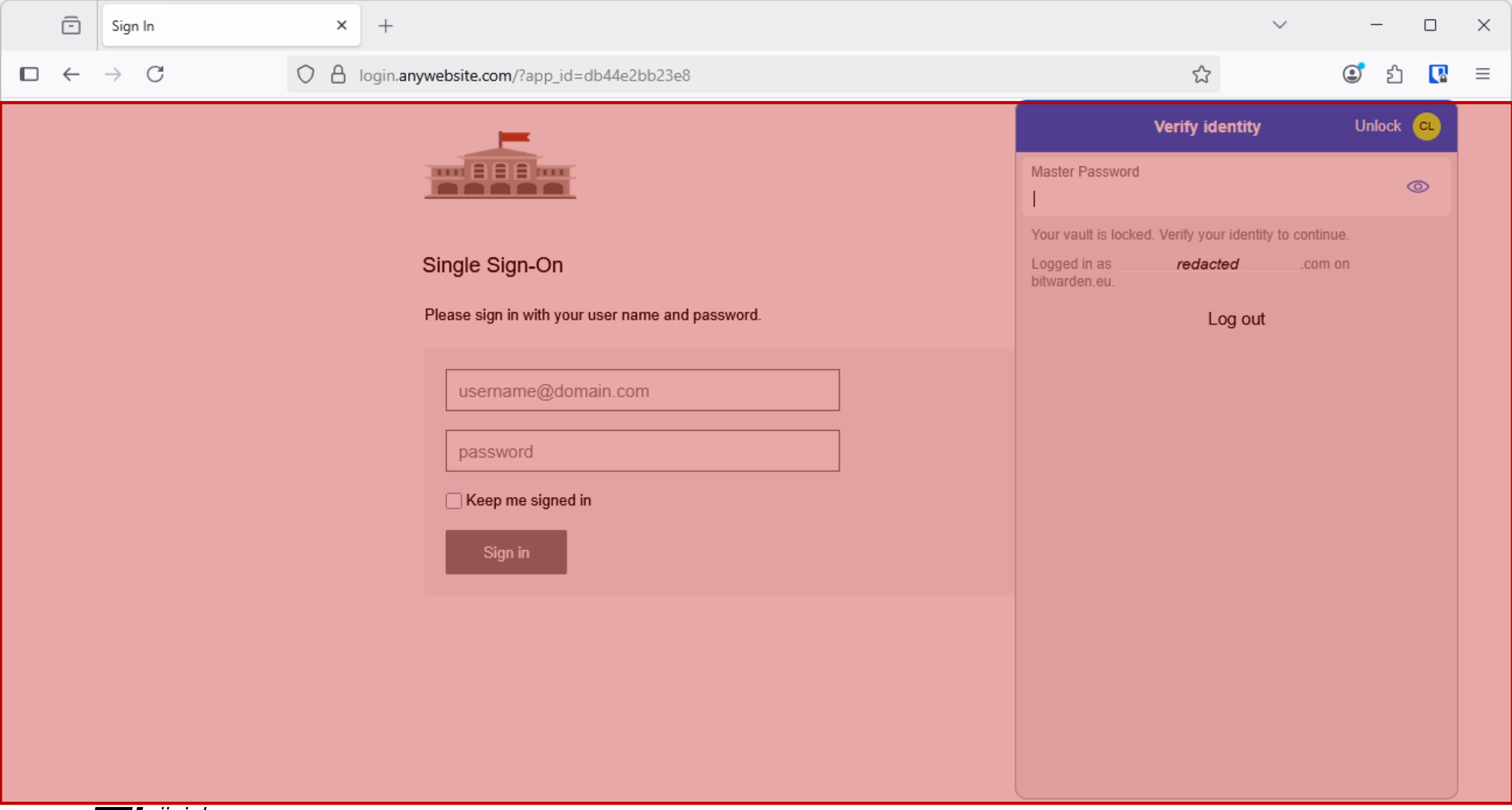
Sign in


Sign In
login.anywebsite.com/?app_id=db44e2bb23e8
Single Sign-On
Please sign in with your user name and password.
username@domain.com
password
Keep me signed in
Sign in


Sign In
login.anywebsite.com/?app_id=db44e2bb23e8
Single Sign-On
Please sign in with your user name and password.
username@domain.com
Unlock your account to view matching logins
Unlock account
Keep me signed in
Sign in

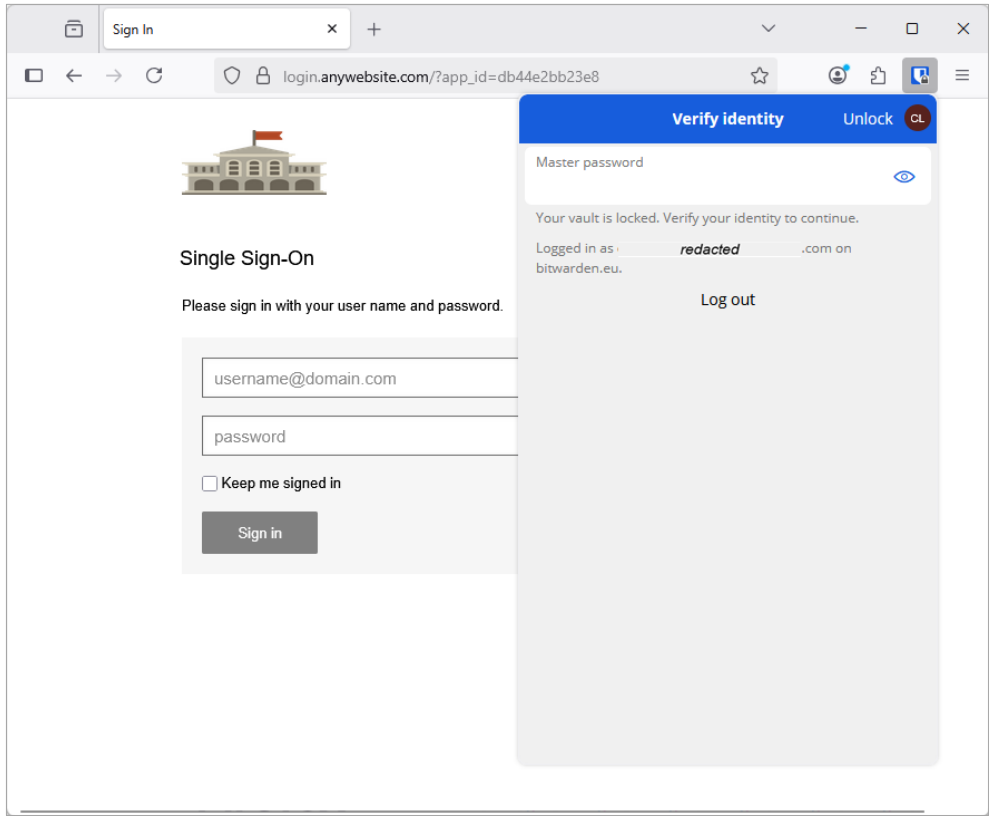

Sign In
login.anywebsite.com/?app_id=db44e2bb23e8
Single Sign-On
Please sign in with your user name and password.
username@domain.com
password
Keep me signed in
Sign in
Verify identity
Unlock
CL
Master Password
Your vault is locked. Verify your identity to continue.
Logged in as redacted .com on bitwarden.eu.
Log out


Sign In
login.anywebsite.com/?app_id=db44e2bb23e8
Single Sign-On
Please sign in with your user name and password.
username@domain.com
password
Keep me signed in
Sign in
Verify identity
Unlock
CL
Master Password
Your vault is locked. Verify your identity to continue.
Logged in as redacted .com on bitwarden.eu.
Log out

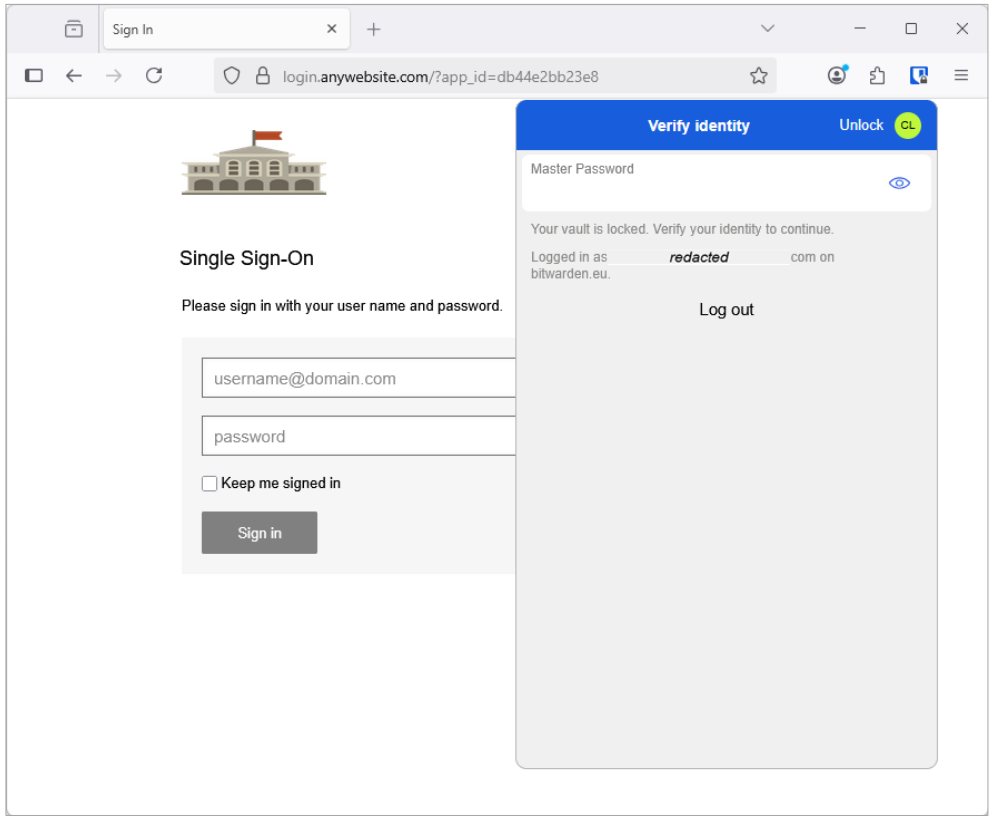

Sign In
login.anywebsite.com/?app_id=db44e2bb23e8
Single Sign-On
Please sign in with your user name and password.
username@domain.com
password
Keep me signed in
Sign in
Verify identity
Unlock
CL
Master Password
Your vault is locked. Verify your identity to continue.
Logged in as redacted .com on bitwarden.eu.
Log out

Problem: Impersonating Browser Extensions is too easy.

Real extension popup

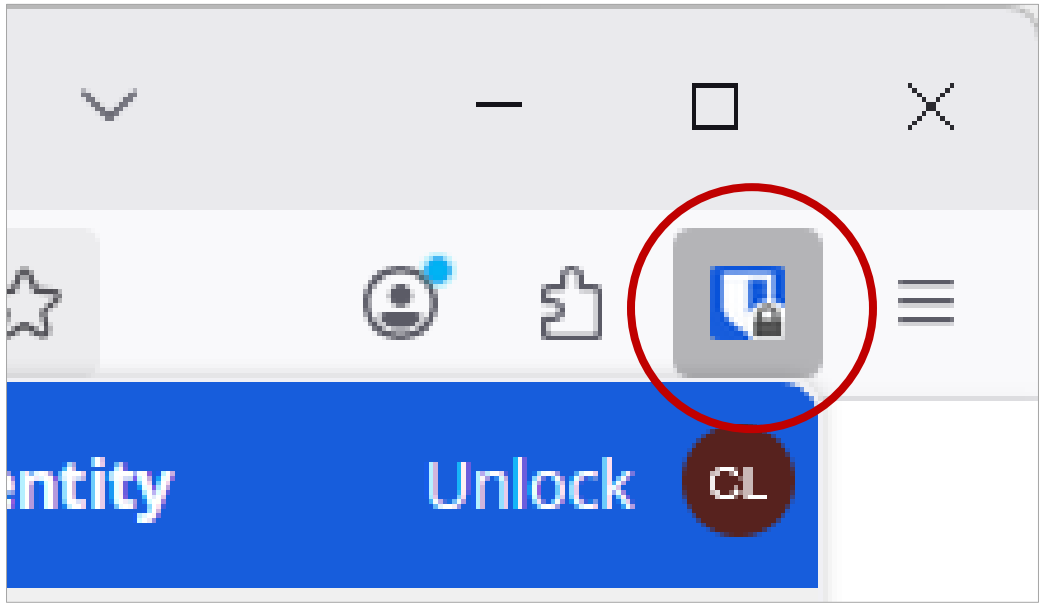


Impersonation

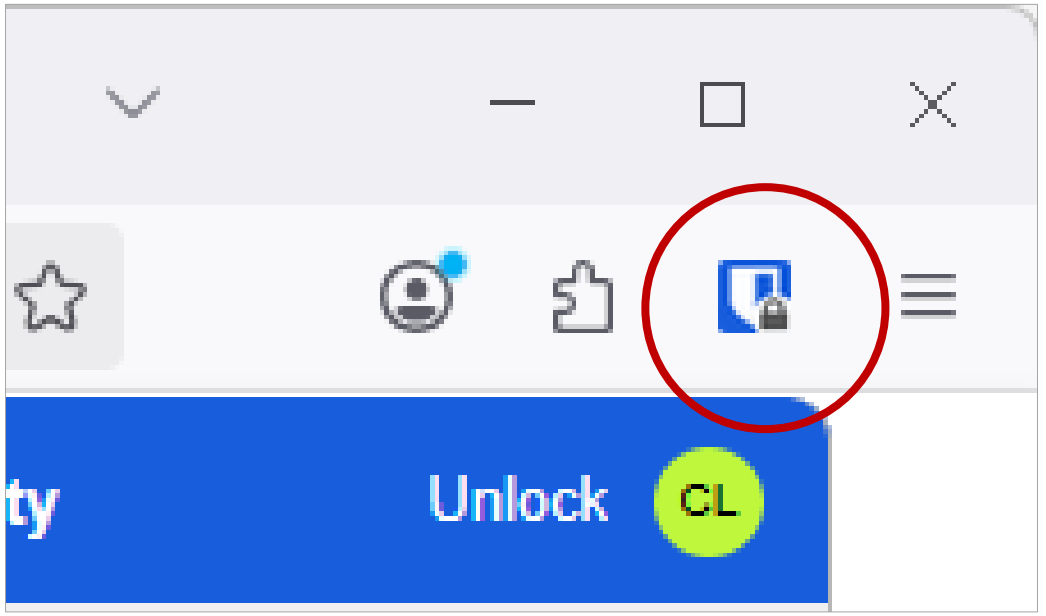


Problem: Impersonating Browser Extensions is too easy.

Real extension popup

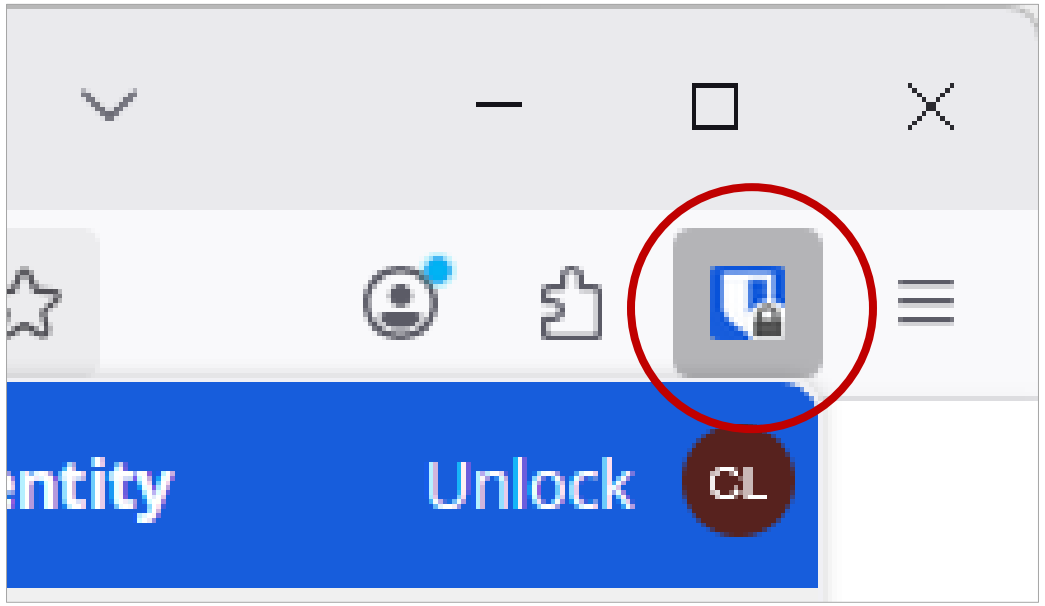


Impersonation

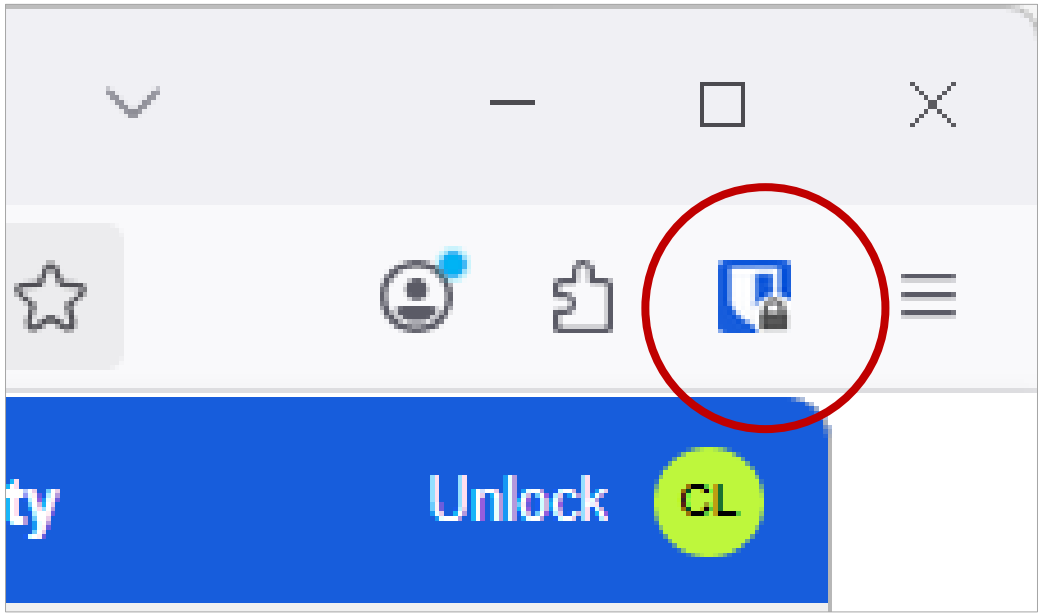


Problem: Impersonating Browser Extensions is too easy.

Real extension popup



Impersonation



Note: Any website, even a compromised legitimate one, could try to phish password manager credentials.

~~Do password managers protect against phishing?~~

Can we phish a password manager's *master password*?

The most common tool recommended to protect from phishing

The *master password* of a manager is a treasure trove:

1. Unlocks local manager **and** logs in to web version
2. **All user credentials** hidden behind its password

Hard targets for attackers: used from extensions & clients

Anliker, Lain, Capkun. *"Phishing Attacks Against Password Manager Browser Extensions"*. In **USENIX Security '25**

Phishing password managers: real-world assessment

First **large-scale study** on **password manager extension phishing**

1. Ran a phishing simulation with **29,809 participants**
2. One-shot phish against all ETH Zurich students and staff
3. Diverse and technical population
4. Tested **4 commercial products**

(LastPass, 1Password, Bitwarden, and Dashlane)

Necessary methodology: attack on alertness → must be field-tested

Phishing password managers: study results

Highly successful in practice

Observed similar success across:

1. Different OSes
2. Browser extensions vs native clients
3. Different modern UI trust indicators
4. Perfect and imperfect replicas

Issue: **reliance on master password**

PM	Group	Detected	Master password	
		#	#	of det.
Bitwarden	$\mathbf{B}_{Ext}$	172	46	26.74%
	$\mathbf{B}_{Ext,Win}$	57	14	24.56%
	$\mathbf{B}_{AW,Win}$	47	9	19.15%
	all	*219*	*55*	*25.11%*
LastPass	$\mathbf{L}_{Ext}$	27	0	0.0%
	$\mathbf{L}_{Page}$	30	3	10.00%
	all	*57*	*3*	*5.26%*
1Password	$\mathbf{1P}_{Ext}$	44	19	43.18%
	$\mathbf{1P}_{NoPic}$	50	20	40.00%
	$\mathbf{1P}_{Safari}$	44	23	52.27%
	all	*138*	*62*	*44.93%*
Dashlane	$\mathbf{D}_{Ext}$	34	20	58.82%
All PMs	-	**448**	**140**	**31.25%**

Common wisdom – Enterprise Edition

1. Phishing training helps its ~~victims~~ pupils

   → largely ineffective across groups that need it

2. If only people knew more about phishing, they wouldn't fall for it

   → need attention & awareness, how it is delivered not significant

3. **Password managers are a complete solution to the problem**

   → moves "old vulnerability" to different attack surface

What to do?

Existing solutions:

Indicate companies where to **invest effectively** → detection, prevention

Focus on attention in critical security decision moments

Today's changes:

Experiment with **better received attention- & awareness-increasing techniques**

(e.g., Google's "Fire drill" phishing exercises)

Tomorrow's changes:

AI as a defensive assistance opportunity…

…But also a complex high-privilege system already difficult to use

Daniele Lain

Postdoctoral Researcher
System Security group @ ETH Zurich

daniele.lain@inf.ethz.ch

daniele.lain.fyi